Güvenlik Raporu — Kütüphane Popülerlik Karşılaştırıcı

2026-10-28 · Müesser İrem Gecici

Bulut Bilişim ve Siber Güvenlik · Haftalık Sprint: Güvenli Bulut Yayını · Müesser İrem Gecici, 2516016027 · Öğr. Gör. Osman Can Çetlenbik

1. Yönetici özeti

Kütüphane Popülerlik Karşılaştırıcı Cloudflare Pages'te 0 TL maliyetle yayında. Kod ve bulut tarafında yüksek veya orta riskli açık bulgu yok. Ürün anahtar gerektiren hiçbir kaynak kullanmadığı için en büyük risk geliştirici ve bulut hesaplarının ele geçirilmesi; bu tehdit iki hesapta 2FA, korumalı ana dal ve en az yetkiyle 20 risk puanından 5'e indirildi.

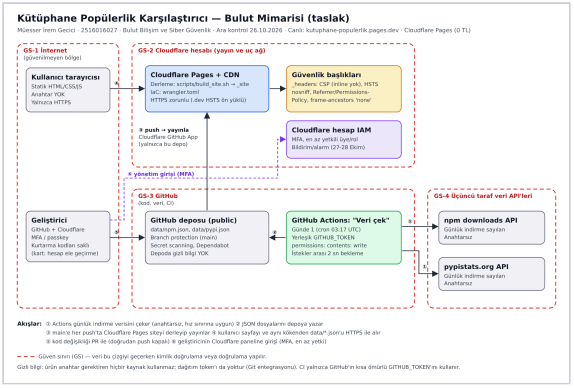
Gösterge	Sonuç
Canlı ürün	kutuphane-populerlik.pages.dev
Depo	github.com/Miremgecici/kutuphane-populerlik
OWASP ZAP (kendi adresimize)	Önce: 1 orta + 1 düşük → Sonra: **0 yüksek / orta / düşük**
Mozilla HTTP Observatory	**A+**, 150/100, 12/12 test
securityheaders.com	**A+**
Gizli anahtar	Depoda, istemcide ve log'larda **0**; gitleaks her push'ta temiz
Tehdit modeli	STRIDE, 11 tehdit; en yüksek risk 20 → 5
Maliyet	**0 TL** (Cloudflare Pages ve GitHub Actions ücretsiz katman)

Kalan en önemli riskler: geliştirici cihazının kötü amaçlı yazılımla ele geçirilmesi ve veri sağlayıcı API'lerinin uzun süre çalışmaması (bölüm 7).

Platform notu: Önce Azure for Students denendi; üniversite hesabıyla giriş başarılı olmasına rağmen portal "Bu kaynağa erişiminiz yok" hatası verdi (26.10.2026). Ödevde izin verilen Cloudflare ücretsiz katmanına geçildi ve durum ara kontrolde bildirildi.

2. Mimari

Ürün sunucusuz ve statik: veri günde bir kez GitHub Actions ile çekilip depoya yazılıyor, Cloudflare Pages her değişiklikte siteyi yeniden yayınlıyor, tarayıcı yalnızca aynı kaynaktaki dosyaları okuyor.



Güven sınırı	Bileşenler	Sınırdaki kontrol
GS-1 İnternet	Kullanıcı tarayıcısı, geliştirici	Yalnızca HTTPS (HSTS); tarayıcıya gizli bilgi gitmez
GS-2 Cloudflare	Pages + CDN, güvenlik başlıkları, hesap IAM	CSP ve diğer başlıklar; panel girişi MFA; en az yetkili ikinci kimlik
GS-3 GitHub	Depo, Actions, Dependabot	Korumalı `main` (PR zorunlu); iş akışları `permissions: {}`; Cloudflare uygulaması tek depoya yetkili
GS-4 Dış API	npm downloads, pypistats.org	Anahtarsız; günde 1 çalışma, istekler arası 2 sn

Kod olarak altyapı: `wrangler.toml` (Pages yapılandırması), `_headers` (güvenlik başlıkları), `scripts/build_site.sh` (yayınlanacak dosyaların izin listesi), `.github/` (CI/CD, tarama, izleme). Panelden yapılanlar: Pages projesinin GitHub'a bağlanması ve derleme komutu, hesap güvenliği ayarları, ruleset.

Kimlikler ve en az yetki

Kimlik	Yetki	Neden gerekli
Cloudflare Workers and Pages (GitHub App)	Yalnızca bu depo	Push'ları görüp siteyi yayınlamak ve sonucu commit'e yazmak
"Veri çek" işi (`GITHUB_TOKEN`)	`contents: write`, `pull-requests: write`	Veriyi dala yazıp PR açmak ve birleştirmek
"ZAP" işi	`contents: write`, `pull-requests: write`	Raporları `docs/zap/` altına PR ile kaydetmek
"İzleme" işi	`contents: read`, `issues: write`	Kontrol script'ini okumak, ALARM issue'su açıp kapatmak
"gitleaks" işi	`contents: read`	Depo geçmişini taramak
Cloudflare okuma kimliği	Yalnızca okuma	Günlük inceleme ve demo; değişiklik yapamaz
Cloudflare Super Administrator	Tam yetki	Yalnızca hesap, üye ve faturalama yönetimi; MFA'lı

3. Tehdit modeli (STRIDE)

Diyagramdaki altı veri akışı üzerinde 11 tehdit belirlendi. Önlemlerden önce 2 yüksek ve 7 orta riskli tehdit vardı; önlemlerden sonra 11'i de düşük riskte (en fazla 5 puan). Risk = olasılık (1–5) × etki (1–5); 1–5 düşük, 6–12 orta, 15–25 yüksek. Tam tablo: docs/tehdit-modeli.md

#	STRIDE	Tehdit	Önce	Alınan önlem	Kalan
T1	S	**GitHub hesabının ele geçirilmesi (kart)**	20	TOTP ile 2FA, kurtarma kodları, oturum/uygulama incelemesi, PR zorunlu ana dal, gitleaks	5
T2	S	**Cloudflare hesabının ele geçirilmesi (kart)**	15	MFA, Super Admin yalnızca yönetim için, okuma yetkili ayrı kimlik, audit log, ödeme yöntemi yok	4
T3	T	`main`'e onaysız / kötü niyetli push	12	Ruleset: PR zorunlu, force push ve silme yasak; veri bile PR ile	4
T4	T	Tedarik zinciri: Action etiketinin değiştirilmesi	10	Tüm Actions SHA ile sabit, Dependabot, `permissions: {}`	4
T7	D	Veri API'lerinin çökmesi / hız sınırı	9	Son başarılı JSON, service worker, 2 sn bekleme, 48 saat alarmı	4
T5	T/E	XSS (veriden gelen metin)	8	CSP `script-src 'self'`, `textContent`, URL parametre izin listesi	3
T6	I	Anahtarın depoya / log'a sızması	8	Anahtarsız mimari, gitleaks, secret scanning + push protection, runbook	3
T9	E	İş akışında fazla yetki / girdi enjeksiyonu	8	İş bazında izin, girdi regex doğrulaması, `pull_request_target` yok	3
T8	D	Yoğun trafik / DoS ve maliyet	6	Statik site + Cloudflare CDN, ücretsiz katman, bütçe uyarısı	2
T10	R	Değişikliklerin izlenememesi	4	PR ve commit geçmişi, GitHub security log, Cloudflare audit log	2
T11	I/T	Clickjacking	4	`frame-ancestors 'none'`, `X-Frame-Options: DENY`	1

Kart tehdidi: geliştirici ve bulut hesabının ele geçirilmesi

Ürünün kendisinde gizli bilgi yok; bu yüzden saldırgan için en kısa yol hesabın kendisi. GitHub hesabını ele geçiren biri koda zararlı script ekleyip Cloudflare üzerinden tüm ziyaretçilere dağıtabilir.

Senaryo	Nasıl olur	Önleyen kontrol
Kimlik avı	Sahte giriş sayfası şifreyi ve TOTP kodunu çalar	Şu an TOTP 2FA (şifre tek başına yetmez). Sonraki adım: alan adına bağlı **passkey**; sahte sitede çalışmaz
Zayıf / tekrar kullanılan şifre	Başka bir sitenin sızıntısındaki şifre denenir	Benzersiz şifre + zorunlu MFA
MFA cihazının kaybı	Telefon kaybolur, hesaba erişilemez	Çevrimdışı saklanan kurtarma kodları
Oturum çerezi çalınması	Kötü amaçlı eklenti oturumu çalar	Oturum listesi incelemesi, tanınmayanları kapatma
Unutulmuş uygulama / token	Eski OAuth uygulaması ya da token kötüye kullanılır	Erişim incelemesi; Cloudflare uygulaması tek depoyla sınırlı
Kök hesabın günlük kullanımı	Super Administrator ile her gün giriş saldırı yüzeyini büyütür	Super Admin yalnızca yönetimde; günlük inceleme okuma yetkili kimlikle

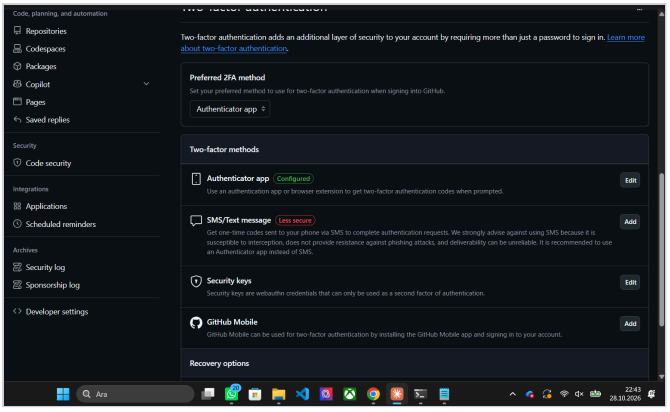
Tespit: GitHub ve Cloudflare yeni oturum e-postaları, GitHub security log, Cloudflare audit log, izleme iş akışının başlık değişikliği alarmı.

4. Uygulanan kontroller

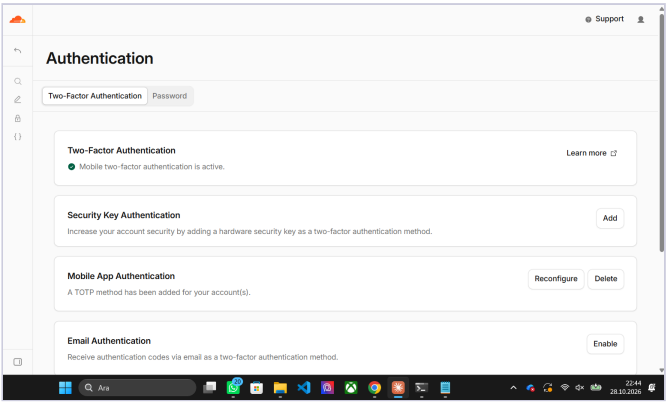
4.1 Kart kontrolü: hesap güvenliği (IAM sertleştirme)

Kontroller GitHub ve Cloudflare hesaplarında uygulandı; denetim listesi ve erişim incelemesi: docs/hesap-guvenligi.md.

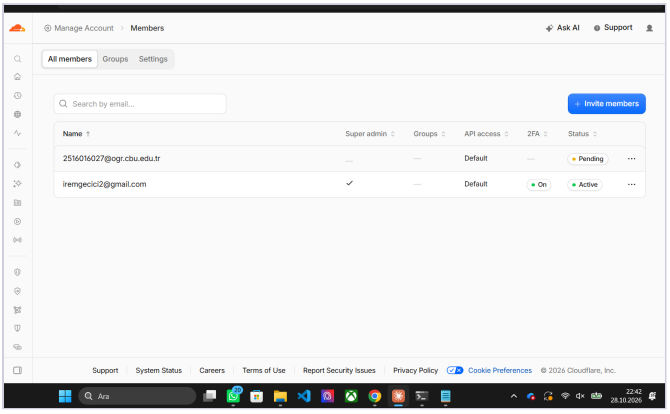
Kart gereksinimi	GitHub	Cloudflare
MFA (tercihen passkey)	TOTP doğrulama uygulaması (passkey sonraki adım)	TOTP doğrulama uygulaması
Kök hesabın kilitlenmesi	(GitHub'da kök hesap kavramı yok; depo sahibi hesabı MFA'lı)	Super Administrator yalnızca hesap ve üye yönetimi için, MFA'lı
Ayrı IAM kullanıcısı / rolü	Cloudflare uygulaması tek depoya; iş akışları iş bazında izinli	Okuma yetkili ikinci kimlik (okul e-postası üyeliği ya da yalnızca okuma izinli API token'ı)
Kurtarma kodları	İndirildi, çevrimdışı saklı	İndirildi, çevrimdışı saklı
Erişim incelemesi	Oturumlar, yetkili uygulamalar, token'lar	Üyeler, API token'ları, audit log



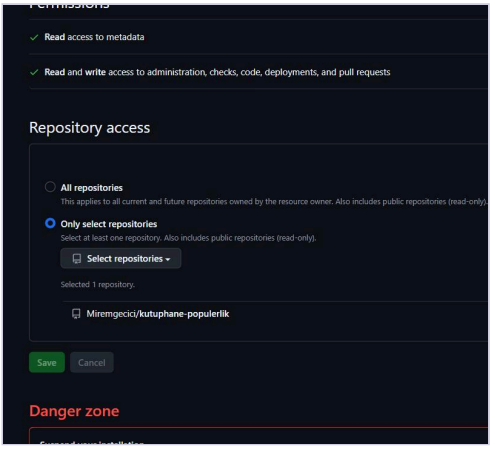
GitHub → Settings → Password and authentication, 28.10.2026 22:43. Authenticator app (TOTP) yapılandırıldı; kurtarma kodları indirildi ve çevrimdışı saklıyor.



Cloudflare → My Profile → Authentication, 28.10.2026 22:44. Mobil uygulama (TOTP) ile 2FA aktif; yedek kodlar üretildi ve çevrimdışı saklıyor.



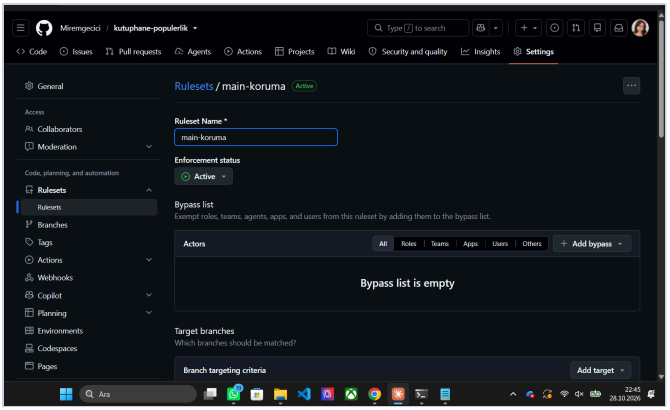
Cloudflare → Manage Account → Members, 28.10.2026 22:42. iremgecici2@gmail.com: Super admin, 2FA açık, aktif. 2516016027@ogr.cbu.edu.tr: "Administrator Read Only" rolüyle davet edildi; davet 23:01'de kabul edildi, kimlik aktif ve 2FA açık.



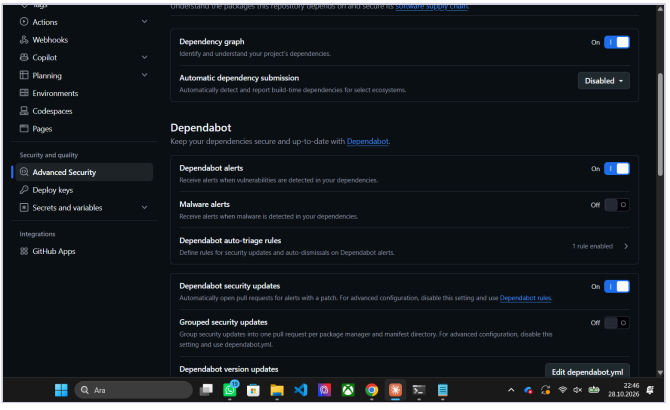
4.2 Gizli anahtarlar ve CI/CD

Gereksinim	Uygulama	Dosya
Anahtar istemcide, depoda, log'da yok	Ürün anahtarsız API'ler kullanıyor; dağıtım token'ı yok (Cloudflare GitHub uygulaması)	—
Actions'ta en az yetki	Varsayılan `permissions: {}`, izinler iş bazında	`.github/workflows/*.yml`
Secret scanning	gitleaks (her push, PR, haftalık) + GitHub secret scanning ve push protection	`guvenlik-taramasi.yml`

Gereksinim	Uygulama	Dosya
Bağımlılık taraması	Dependabot haftalık; ilk güncelleme PR'ı #1 açıldı ve CI'dan geçti	`.github/dependabot.yml`
Tedarik zinciri	Tüm Actions commit SHA'sı ile sabitlendi	tüm iş akışları
Branch protection	Ruleset: PR zorunlu, force push ve silme yasak; otomatik veri güncellemesi de PR ile geliyor	`scripts/pr_ile_birlestir.sh`



Depo → Settings → Rulesets → main-koruma, 28.10.2026 22:45. Durum Active, bypass listesi boş; kurallar: silme yasak, force push yasak, PR zorunlu. Doğrudan push denemesinin reddi bölüm 5.3'te.



Depo → Settings → Advanced Security, 28.10.2026 22:46. Dependency graph, Dependabot alerts ve Dependabot security updates açık; Secret Protection ve push protection da açık, Private vulnerability reporting etkin.

4.3 Web uygulaması güvenliği

Başlık / dosya	Değer	Neye karşı
Content-Security-Policy	`default-src 'self'; script-src 'self'; style-src 'self'; connect-src 'self'; object-src 'none'; frame-ancestors 'none'; upgrade-insecure-requests` (+ manifest, worker, img)	XSS, dış kaynaktan kod; `unsafe-inline` / `unsafe-eval` yok
Strict-Transport-Security	`max-age=31536000; includeSubDomains`	HTTPS'ten HTTP'ye düşürme
X-Content-Type-Options	`nosniff`	MIME tahmini
Referrer-Policy	`strict-origin-when-cross-origin`	Adres sızıntısı
Permissions-Policy	kamera, mikrofon, konum, ödeme, USB kapalı	Gereksiz cihaz izni
X-Frame-Options / frame-ancestors	`DENY` / `'none'`	Clickjacking
COOP / CORP / COEP	`same-origin` / `same-origin` / `require-corp`	Siteler arası sızıntı
Access-Control-Allow-Origin	Cloudflare'in varsayılan `*` değeri kaldırıldı	Siteler arası okuma (ZAP bulgusu)
`/.well-known/security.txt`, `SECURITY.md`	Güvenlik açığı bildirim adresi	Sorumlu bildirim

Uygulama tarafında metinler `textContent` ile yazılıyor (`innerHTML` yok) ve URL parametreleri izin listesiyle doğrulanıyor.

5. Test sonuçları

5.1 OWASP ZAP baseline taraması (önce / sonra)

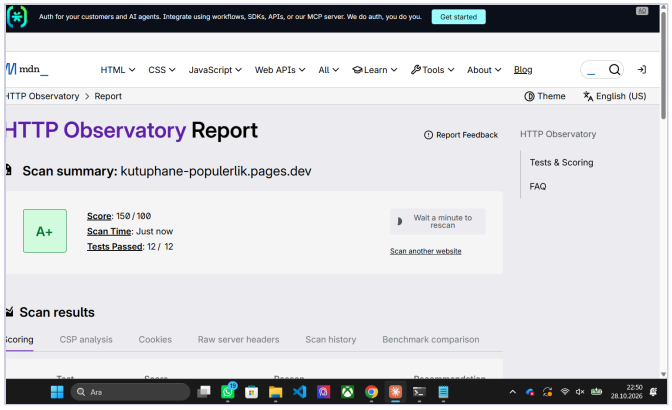
Tarama yalnızca kendi ürün adresimize, GitHub Actions üzerinden yapıldı (pasif baseline + AJAX spider). Önce: 28.10.2026 16:02 UTC; sonra: 28.10.2026 16:06 UTC, düzeltmeler yayınlandıktan sonra. Raporlar: docs/zap/once · docs/zap/sonra

Risk seviyesi	Önce	Sonra
Yüksek	0	0
Orta	1	**0**
Düşük	1	**0**

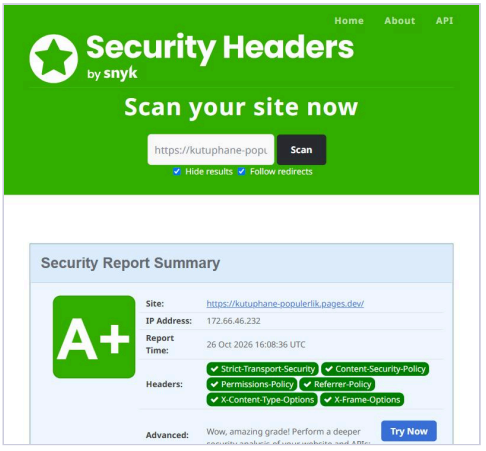
Risk seviyesi	Önce	Sonra
Bilgilendirme	9	9

Bulgu	Risk	Düzeltme / gerekçe	Durum
Cross-Domain Misconfiguration (`Access-Control-Allow-Origin: *`)	Orta	Cloudflare'in varsayılan başlığı `_headers` içinde `! Access-Control-Allow-Origin` ile kaldırıldı	Düzeltildi
Cross-Origin-Embedder-Policy eksik	Düşük	`Cross-Origin-Embedder-Policy: require-corp` eklendi; tüm kaynaklar aynı kökenden olduğu için sayfa etkilenmedi	Düzeltildi
User Controllable HTML Element Attribute (`olcek`, `donem`)	Bilgi	Parametreler izin listesiyle doğrulanıyor; `olcek` kontrolü `Object.hasOwn` ile sıkılaştırıldı (`constructor` gibi değerler artık reddediliyor)	Düzeltildi (yanlış pozitif kalıyor)
Information in Browser localStorage	Bilgi	Kasti: son başarılı herkese açık veri, API çalışmazsa göstermek için saklanıyor; kişisel veri yok	Kabul edildi
Base64 Disclosure	Bilgi	Yanıttaki sıkıştırılmış / ikili içerik; gizli bilgi değil	Yanlış pozitif
Sec-Fetch-Dest / Mode / Site / User eksik (4)	Bilgi	Bunlar istek başlıkları; ZAP'ın kendi istemcisi göndermiyor, sunucuyla ilgili değil	Yanlış pozitif
Re-examine Cache-control / Storable but Non-Cacheable	Bilgi	Kasti: `max-age=0, must-revalidate` ile her ziyarette güncel sürüm; çevrimdışı için service worker var	Kabul edildi

5.2 Güvenlik başlıkları testleri



Mozilla HTTP Observatory, 28.10.2026 22:50: A+, 150/100, 12/12 test. ZAP düzeltmesiyle eklenen COEP başlığı puanı 140'tan 150'ye çıkardı.



securityheaders.com raporu, 26.10.2026 16:08 UTC (rapor zamanı görüntüde yazıyor).

5.3 Kart doğrulama testi: en az yetkili kimliğin yapamadığı işlem

Adım	Beklenen	Sonuç
Okuma yetkili kimlikle Cloudflare → Workers & Pages → kutuphane-populerlik	Proje ve yayın listesi görünür	Kimlik hazır: okul e-postası "Administrator Read Only" rolüyle aktif, 2FA açık (28.10.2026). Canlı deneme demoda gösterilecek.
Aynı kimlikle Settings → Builds → derleme komutunu değiştirmeyi dene	Reddedilir	Demoda canlı gösterilecek
Aynı kimlikle bir yayını silmeyi / yeniden başlatmayı dene	Reddedilir	Demoda canlı gösterilecek
Ruleset açıkken `main`'e doğrudan push	"Changes must be made through a pull request" ile reddedilir	**Reddedildi (28.10.2026 19:22): "GH013: Repository rule violations found for refs/heads/main. Changes must be made through a pull request." Ardından Dependabot PR #1 aynı kural altında PR ile birleştirildi.**

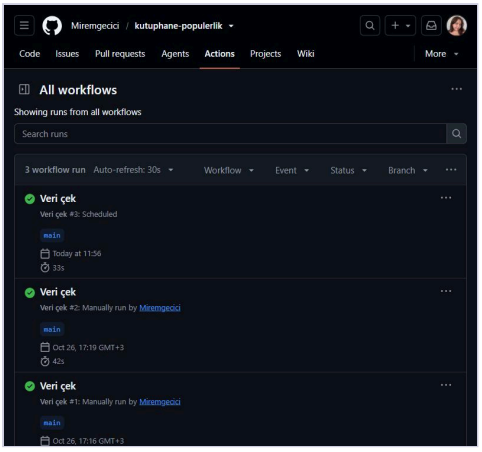
Not: Okuma yetkili kimliğin rolü ve aktifliği bölüm 4.1'deki Members ekranında görülüyor. Bu kimlikle ayar değiştirme denemesinin reddedilmesi demoda canlı gösterilecek. Ana dal kuralının doğrulaması (son satır) tamamlandı.

6. İzleme, alarm ve olay müdahalesi

İzleme iş akışı ürünü 6 saatte bir kontrol ediyor ve bir kontrol bile başarısız olursa `ALARM` etiketli bir issue açıp e-posta gönderiyor; sorun düzelince issue kendiliğinden kapanıyor. 28.10.2026'daki iki test çalışması başarılı geçti.

Kontrol	Alarm koşulu
Ana sayfa erişimi	HTTP 200 dışında bir yanıt
Güvenlik başlıkları	CSP, HSTS, nosniff, Referrer-Policy veya Permissions-Policy eksik; CSP'de `unsafe-inline` / `unsafe-eval`
HTTPS yönlendirmesi	HTTP isteği HTTPS'e yönlenmiyor
security.txt	Yayında değil
Veri tazeliği	`data/*.json` 48 saatten eski

Log / alarm kaynağı	Nerede
İzleme log'ları	GitHub Actions → "İzleme ve alarm" çalışma kayıtları (`scripts/saglik_kontrolu.sh` çıktısı)
Veri çekme log'ları	GitHub Actions → "Veri çek"; paket hataları ayrıca JSON'daki `errors` alanında
Yayın log'ları	Cloudflare Pages → Deployments; her commit'te Cloudflare durum kontrolü
Alarm 1	`ALARM` issue'su + GitHub e-postası
Alarm 2	Başarısız iş akışı (gitleaks, veri çekme) e-postası
Alarm 3	Cloudflare her commit'te yayın durumunu GitHub'a yazıyor (başarısız yayın commit'te kırmızı görünür)



Olay müdahale runbook'u: "API anahtarım sızdı"

Tam metin: docs/runbook-anahtar-sizintisi.md. Hedef: tespitten sonraki 15 dakika içinde iptal.

1. **Tespit (0–5 dk):** gitleaks kırmızı, GitHub secret scanning uyarısı, sağlayıcı e-postası ya da beklenmeyen etkinlik. Hangi anahtar, nerede, ne zaman: not al.
2. **İptal (5–15 dk):** Commit'i silmek yetmez; önce sağlayıcıda iptal (GitHub token → Delete; Cloudflare token → Roll / Delete). Hesaptan şüphe varsa şifre değişikliği ve tüm oturumları kapatma.
3. **Yenileme (15–30 dk):** Yeni anahtar en az yetki ve son kullanma tarihiyle, yalnızca GitHub Secrets'ta; iş akışı elle çalıştırılıp doğrulanır.
4. **İnceleme (aynı gün):** `git log -S` ile sızıntının başlangıcı; GitHub security log ve Cloudflare audit log'da kötüye kullanım; gerekirse `git filter-repo`; kök neden.
5. **Bildirim (aynı gün):** Sağlayıcıya ve ekibe / öğretim elemanına; olay kaydı `docs/olaylar/` altına şablonla.

7. Kalan riskler ve maliyet

Kalan riskler

Risk	Neden kalıyor	Kabul / sonraki adım
Geliştirici cihazının kötü amaçlı yazılımla ele geçirilmesi (T1, kalan 5)	TOTP gerçek zamanlı kimlik avıyla çalınabilir (passkey henüz yok); cihaz ele geçirilirse oturum çalınabilir	Passkey eklemek, güncel işletim sistemi ve tarayıcı, eklentileri azaltma, oturum incelemesi

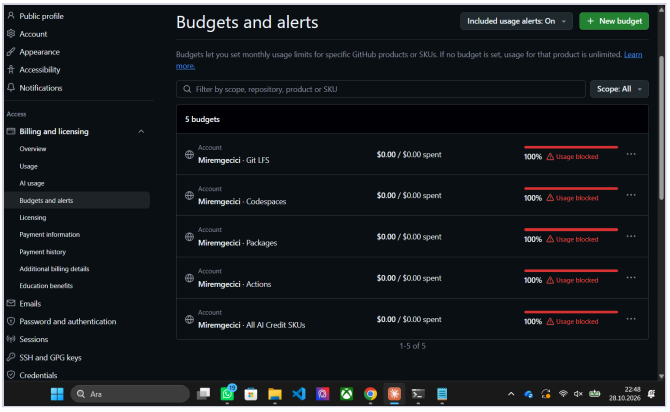
Risk	Neden kalıyor	Kabul / sonraki adım
Kurtarma kodlarının kaybı / çalınması	Kodlar fiziksel olarak saklandığı yerde risk taşır	Kodları iki ayrı güvenli yerde saklamak
Veri API'lerinin uzun süre çalışmaması (T7, kalan 4)	Kaynak üçüncü tarafa ait	Son başarılı veri gösteriliyor ve kullanıcı uyarılıyor; 48 saatte alarm
Cloudflare veya GitHub'ın kendisinde kesinti	Platform riski	Kabul edildi; statik site olduğu için başka bir platforma taşımak kolay
`.pages.dev` alt alan adı	Kendi alan adımız yok; DNSSEC ve CAA gibi kontroller bizde değil	Kabul edildi; alan adı alınırsa eklenecek
ZAP bilgilendirme bulguları (9)	Kasti tasarım ya da yanlış pozitif (bölüm 5.1)	Kabul edildi
OpenSSF Scorecard	Depo yeni olduğu için "Maintained" ve "Code-Review" gibi kontroller düşük puan alır	Bonus hedeflenmedi

Maliyet

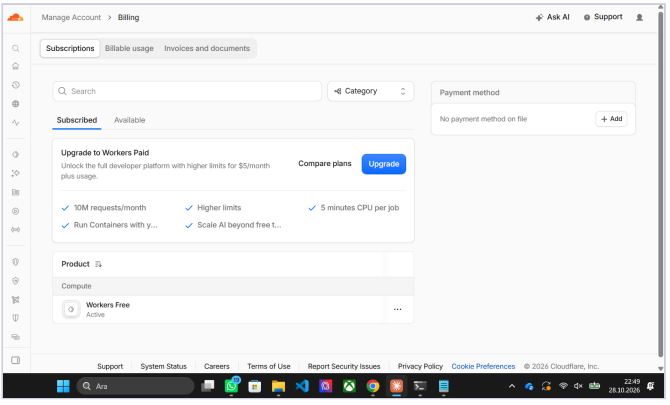
Aylık maliyet **0 TL**; ayrıca hiçbir hesapta ücret çıkabilecek bir ayar yok.

Kalem	Plan	Kullanım	Tahmini maliyet
Cloudflare Pages	Free (sınırsız istek ve bant genişliği, ayda 500 derleme)	Günde ~2–5 derleme	0 TL
GitHub Actions	Herkese açık depo, ücretsiz	Günde ~6 çalışma, her biri 1 dakikadan kısa (ZAP ~4 dk, elle)	0 TL
GitHub depo, Dependabot, secret scanning	Herkese açık depo, ücretsiz	—	0 TL
Toplam			**0 TL**

Maliyet alarmı: Cloudflare hesabında ödeme yöntemi tanımlı değil, bu yüzden ücret çıkamaz. GitHub'da Actions için 0 USD bütçe ve %100 uyarısı tanımlı.



GitHub → Settings → Billing and licensing → Budgets and alerts, 28.10.2026 22:48. Actions, Packages, Codespaces, Git LFS ve AI kredileri için 0 USD bütçe (aşılırsa kullanım durdurulur), dahil kullanım uyarıları açık. Herkese açık depoda Actions ücretsiz olduğu için harcama $0.00.



Cloudflare → Manage Account → Billing, 28.10.2026 22:49. Workers Free aktif, "No payment method on file": hesaptan ücret çıkması mümkün değil.

Ekler (depoda)

- Tehdit modeli: `docs/tehdit-modeli.md`
- Hesap güvenliği denetim listesi ve erişim incelemesi: `docs/hesap-guvenligi.md`
- Runbook: `docs/runbook-anahtar-sizintisi.md`
- ZAP raporları: `docs/zap/once/`, `docs/zap/sonra/`
- İş akışları: `.github/workflows/` · Güvenlik başlıkları: `_headers` · IaC: `wrangler.toml`

Yapay zekâ beyanı: Bu rapor ve depodaki güvenlik yapılandırmaları hazırlanırken Claude (Anthropic) kullanıldı; hesap güvenliği ayarları ve doğrulama testleri tarafımdan yapıldı. Ayrıntılar README'de.